

Consigne générale : Vous devez capturer chaque étape et mettre des explications pour chaque capture. Toutes les captures et les explications doivent être dans un fichier Word contenant les noms et prénoms de chaque membre du groupe. C'est ce fichier Word qui est à rendre.

EXERCICE 1 : SÉCURISATION, SEGMENTATION ET RESTRUCTURATION D'UNE INFRASTRUCTURE RÉSEAU VIRTUALISÉE

PHASE 1 : Analyse MoSCoW, Conception et Sécurisation Initiale

Contexte

Vous êtes le RSSI d'une entreprise possédant une infrastructure virtualisée composée de plusieurs machines Linux et Windows.

L'entreprise souhaite :

- segmenter son réseau ;
- sécuriser les communications ;
- limiter les risques liés aux machines offensives ;
- contrôler les flux réseau ;
- intégrer un environnement Active Directory ;
- appliquer une politique de sécurité cohérente.

Infrastructure Disponible

Machine	Adresse IP	Rôle
Parrot Security	À définir	Machine d'audit offensive
Windows Server	À définir	AD DS + DNS + IIS
Debian	À définir	Routeur Linux + Firewall
Windows Client	À définir	Poste utilisateur

Étape Préliminaire — Analyse MoSCoW Obligatoire

Avant toute configuration technique, vous devez réaliser une analyse MoSCoW complète du projet.

Appliquer cette analyse aux éléments suivants :

- segmentation réseau ;
- Active Directory ;
- DNS ;
- Firewall ;
- routage ;
- journalisation ;
- sécurisation des accès ;
- limitation des scans réseau ;
- filtrage entre réseaux ;
- protection contre les attaques internes ;
- isolation de Parrot ;
- IIS.

Justifier chaque choix.

Expliquer :

- pourquoi certains éléments sont prioritaires ;
- quels risques apparaissent si les éléments "Must Have" sont absents.

Réseau Principal Fourni

Réseau de départ :

172.16.50.0/24

L'entreprise souhaite créer les réseaux suivants :

Sous-réseau	Nombre maximal d'hôtes
Réseau Utilisateurs	60
Réseau Serveurs	25
Réseau Sécurité / Audit	12
Réseau Administration	10

Partie A — Gouvernance RSSI et Analyse de Sécurité

1. Définir le rôle du RSSI dans cette infrastructure.
2. Expliquer l'intérêt du subnetting.
3. Donner les différences entre :
 - adresse réseau ;
 - adresse hôte ;
 - adresse broadcast ;
 - passerelle.
4. Donner les risques :
 - d'un réseau plat ;
 - d'un mauvais filtrage ;
 - d'une mauvaise segmentation.
5. Expliquer pourquoi la machine Parrot doit être fortement isolée.
6. Donner les avantages d'un firewall Linux centralisé.
7. Expliquer le principe du moindre privilège.

Partie B — Subnetting et Plan d'Adressage

À partir du réseau :

172.16.50.0/24

1. Réaliser le découpage en sous-réseaux.
2. Déterminer pour chaque sous-réseau :
 - adresse réseau ;
 - masque CIDR ;
 - masque décimal ;
 - première adresse ;
 - dernière adresse ;
 - broadcast ;
 - nombre maximal d'hôtes.
3. Attribuer les sous-réseaux :
 - aux serveurs ;
 - aux utilisateurs ;
 - à Parrot ;
 - aux administrateurs.
4. Justifier les masques choisis.
5. Expliquer pourquoi certains réseaux nécessitent davantage d'adresses.

Partie C — Architecture Multi-Réseaux

Le serveur Debian jouera le rôle de routeur principal.

1. Expliquer pourquoi Debian doit posséder plusieurs interfaces réseau.
2. Donner le rôle :
 - du routeur ;
 - du DNS ;
 - du firewall ;
 - de l'AD DS.

3. Expliquer pourquoi deux réseaux différents ne communiquent pas sans routage.
4. Illustrer le trajet d'un paquet entre :
 - Windows Client ;
 - Windows Server.

Partie D — Attribution IP et Configuration Réseau

1. Attribuer une adresse IP correcte à chaque machine.
2. Donner pour chaque machine :
 - IP ;
 - masque ;
 - passerelle ;
 - DNS ;
 - réseau ;
 - broadcast.
3. Configurer :
 - les interfaces Debian ;
 - les cartes réseau Windows ;
 - la machine Parrot.
4. Vérifier les configurations réseau.
5. Tester les communications.

Partie E — Routage Linux

Sous Debian :

1. Configurer les interfaces réseau.
2. Activer le routage IP.
3. Configurer les routes nécessaires.
4. Vérifier la table de routage.
5. Expliquer le fonctionnement du transfert inter-réseaux.

Partie F — Windows Server et Active Directory

1. Installer :
 - Active Directory ;
 - DNS ;
 - IIS.
2. Créer :
 - deux utilisateurs ;
 - deux groupes.
3. Définir :
 - une stratégie de mot de passe ;
 - des restrictions de connexion.
4. Configurer Windows Client afin :
 - d'utiliser le DNS du serveur ;
 - d'intégrer le domaine.
5. Tester :
 - DNS ;
 - authentification ;
 - accès IIS.

Partie G — Sécurisation et Firewall

1. Écrire un script SHELL permettant :
 - d'autoriser DNS ;

- d'autoriser LDAP ;
 - d'autoriser Kerberos ;
 - d'autoriser IIS ;
 - de limiter ICMP ;
 - de bloquer Telnet ;
 - de filtrer SMB ;
 - de limiter les scans réseau ;
 - de journaliser certaines connexions.
2. Mettre en place des règles iptables adaptées.
 3. Expliquer :
 - INPUT ;
 - OUTPUT ;
 - FORWARD ;
 - DROP ;
 - ACCEPT ;
 - NAT.

Partie H — Analyse de Sécurité

1. Expliquer les conséquences :
 - d'un mauvais masque ;
 - d'une mauvaise passerelle ;
 - d'un DNS incorrect ;
 - d'un routage absent.
2. Expliquer comment un attaquant pourrait exploiter :
 - des ports ouverts ;
 - un réseau mal segmenté ;
 - une mauvaise configuration firewall.
3. Donner plusieurs recommandations RSSI.

Partie I — Rapport Technique Final

Le rapport doit contenir :

- le plan d'adressage ;
- le subnetting ;
- le schéma réseau ;
- les règles firewall ;
- les scripts SHELL ;
- les configurations Debian ;
- les configurations Windows ;
- les tests réalisés ;
- les résultats obtenus ;
- les problèmes rencontrés ;
- les recommandations RSSI.

PHASE 2 : Restructuration et Simulation d'Attaques Contrôlées

Contexte

Après audit de sécurité, l'entreprise décide de restructurer complètement son infrastructure réseau afin :

- d'améliorer la sécurité ;
- de mieux contrôler les communications ;
- de réduire les risques liés à Parrot ;
- de limiter les mouvements latéraux ;

- d'améliorer les politiques de filtrage.

L'entreprise conserve uniquement les 4 machines initiales.

Nouvelle Architecture Réseau

• Réseau Audit / Offensive

Machine	Adresse IP
Parrot Security	192.168.70.10/28
Debian (Audit)	192.168.70.1/28

• Réseau Serveurs

Machine	Adresse IP
Windows Server	192.168.80.10/27
Debian (Serveur)	192.168.80.1/27

• Réseau Utilisateurs

Machine	Adresse IP
Windows Client	192.168.90.10/26
Debian (Utilisateur)	192.168.90.1/26

Partie J — Analyse de la Nouvelle Architecture

1. Identifier pour chaque réseau :
 - adresse réseau ;
 - masque ;
 - broadcast ;
 - première adresse ;
 - dernière adresse ;
 - nombre d'hôtes.
2. Expliquer pourquoi :
 - Audit utilise /28 ;
 - Serveur utilise /27 ;
 - Utilisateur utilise /26.
3. Identifier :
 - le réseau le plus critique ;
 - le plus exposé ;
 - le plus sécurisé.
4. Expliquer pourquoi Parrot doit être isolé.

Partie K — Reconfiguration Réseau

1. Reconfigurer toutes les interfaces Debian.
2. Configurer :
 - Parrot ;
 - Windows Server ;
 - Windows Client.
3. Configurer correctement :
 - passerelles ;
 - DNS ;
 - masques.
4. Tester les communications.

Partie L — Routage Inter-Réseaux

1. Activer le routage IP.

2. Vérifier les tables de routage.
3. Expliquer le fonctionnement du routage.
4. Tester :
 - Windows Client ↔ Windows Server ;
 - Parrot ↔ Windows Server ;
 - Parrot ↔ Windows Client.
5. Expliquer pourquoi certaines communications doivent être bloquées.

Partie M — Simulation d'Attaques Contrôlées depuis Parrot

Réaliser les attaques suivantes :

- **Spear-Phishing Attack Vectors**
- **Mass email Attack**
- **Fileformat Payload**
- **Social Engineering Template**
- **Powershell Attack Vectors**
- **Windows Meterpreter Reverse HTTPS**
- **Windows Meterpreter Reverse DNS**
- **Web Attack Vectors**
- **SCCM Attack Vector**
- **Dell DRAC/Chassis Default Checker**
- **Java Applet Attack Method**
- **Tabnabbing Attack Method**
- **Web Jacking Attack Method**
- **Third Party Modules**

Partie N — Sécurisation Avancée

1. Mettre en place des règles iptables permettant :
 - l'autorisation DNS ;
 - l'autorisation AD DS ;
 - l'autorisation IIS ;
 - le blocage SMB ;
 - le blocage Telnet ;
 - la limitation ICMP ;
 - le filtrage entre réseaux ;
 - l'interdiction d'accès direct de Parrot vers Windows Client.
2. Écrire un script SHELL automatisant :
 - le firewall ;
 - la journalisation ;
 - la protection contre les scans simples ;
 - les restrictions réseau.

Partie O — Services Réseau Windows

1. Configurer DNS.
2. Intégrer Windows Client au domaine.
3. Créer :
 - deux utilisateurs ;
 - deux groupes.
4. Appliquer :
 - restrictions horaires ;

- complexité des mots de passe ;
 - restrictions de session.
5. Configurer IIS et réaliser des tests.

Partie P — Analyse Finale RSSI

1. Expliquer :
 - les risques d'un réseau mal segmenté ;
 - les risques d'un firewall mal configuré ;
 - les risques des ports ouverts.
2. Expliquer comment Debian protège les autres réseaux.
3. Donner plusieurs recommandations RSSI avancées.
4. Proposer des améliorations futures :
 - IDS/IPS ;
 - supervision ;
 - VLAN ;
 - SIEM ;
 - authentification renforcée.

Partie Q — Rapport Technique Final

Le rapport final devra contenir :

- le nouveau plan d'adressage ;
- les sous-réseaux ;
- les règles firewall ;
- les configurations Debian ;
- les configurations Windows ;
- les tests d'attaques ;
- les résultats obtenus ;
- les journaux analysés ;
- les problèmes rencontrés ;
- les solutions mises en place ;
- les recommandations RSSI finales.

EXERCICE 2 : Segmentation réseau et sécurisation pilotées par la méthode MoSCoW

Contexte

Une entreprise possède une petite infrastructure composée de 3 machines :

- **Parrot Security OS** : machine d'audit et d'attaque,
- **Windows** : poste utilisateur,
- **Debian** : serveur hébergeant une base de données clients.

Actuellement, les trois machines se trouvent dans le même réseau :

192.168.100.0/24

L'entreprise souhaite améliorer la sécurité de son infrastructure après avoir constaté plusieurs risques liés à l'absence de segmentation réseau.

Travail demandé

Partie 1 — Analyse stratégique avec la méthode MoSCoW

Avant toute modification technique, vous devez réaliser une **analyse des besoins de sécurité** en utilisant la méthode **MoSCoW**.

Partie 2 — Analyse RSSI

2.1 Identification des actifs

Identifiez :

- les actifs matériels,
- les actifs logiciels,
- les actifs informationnels,
- les services critiques.

2.2 Analyse des menaces

Expliquez les risques liés au fait que Parrot se trouve dans le même réseau que les autres machines.

2.3 Vulnérabilités

Identifiez les vulnérabilités dues :

- à l'absence de segmentation,
- au manque de filtrage réseau,
- à l'exposition des services.

2.4 Impacts métiers

Déterminez les impacts possibles :

- perte de données,
- indisponibilité des services,
- atteinte à la confidentialité,
- perte financière,
- atteinte à l'image de l'entreprise.

2.5 Priorisation des risques

Classez les risques selon leur niveau :

- Critique,
- Élevé,
- Moyen,
- Faible.

Partie 3 — Conception réseau sécurisée

À partir du réseau :

192.168.100.0/24

vous devez proposer une nouvelle architecture réseau.

Contraintes

Vous devez créer :

- un sous-réseau interne pour Windows et Debian,
- un sous-réseau isolé pour Parrot,
- un sous-réseau d'administration.

Pour chaque sous-réseau, donnez :

- Adresse réseau,
- Masque,
- Première adresse utilisable,
- Dernière adresse utilisable,
- Adresse de broadcast,
- Nombre d'hôtes possibles.

Partie 4 — Phase offensive

Situation initiale

Avant la segmentation, les trois machines sont dans le même sous-réseau.

Depuis Parrot, réalisez :

- Web Attack Vectors
- Fileformat Payload
- Metasploit Browser Exploit Method
- Social Engineering Template

- SCCM Attack Vector

Partie 5 — Phase défensive

Après segmentation réseau :

5.1 Configuration réseau

Expliquez :

- comment les sous-réseaux limitent les attaques,
- pourquoi Parrot doit être isolé,
- quels flux doivent rester autorisés.

5.2 Sécurisation Debian avec iptables

Créez un programme SHELL à plusieurs options pour faire en sorte de bloquer ces différentes attaques.

Partie 6 — Analyse finale

Expliquez :

1. Pourquoi la méthode MoSCoW est utile avant une architecture de sécurité.
2. Quels éléments étaient prioritaires dans ce contexte.
3. Comment la segmentation réduit la surface d'attaque.
4. Pourquoi le filtrage réseau complète la segmentation.

EXERCICE 3 : Infrastructure Windows Server sécurisée pilotée par la méthode MoSCoW

Contexte

Une entreprise souhaite moderniser son infrastructure informatique à l'aide des services Microsoft.

L'infrastructure actuelle comporte :

- un serveur sous **Windows Server**,
- deux postes clients sous **Windows (Client)**,
- une machine d'audit de sécurité sous **Parrot Security OS**.

L'entreprise souhaite utiliser :

- Active Directory Domain Services (AD DS),
- DNS,
- DHCP,
- IIS.

Le réseau disponible est :

192.168.50.0/24

Partie 1 — Analyse des besoins avec la méthode MoSCoW

Avant toute configuration technique, vous devez réaliser une analyse des besoins en utilisant la méthode MoSCoW.

Partie 2 — Infrastructure Active Directory

2.1 Domaine Active Directory

L'entreprise possède un nom de domaine (exemple : entreprise.local)

Expliquez :

1. Le rôle d'un contrôleur de domaine.
2. Pourquoi AD DS centralise l'administration.
3. Les avantages d'une authentification centralisée.

2.2 Organisation Active Directory

L'entreprise possède les unités organisationnelles suivantes :

- Direction,
- Informatique,
- Comptabilité,

- Utilisateurs,
- Serveurs.

2.3 Gestion des utilisateurs

Créez les utilisateurs suivants :

Nom	Service
Alice	Direction
Bob	Informatique
Clara	Comptabilité

Partie 3 — DNS et DHCP

Configurez le DNS et le DHCP entre le serveur et le(s) client(s)

Partie 4 — IIS et services Web

Configurez les services IIS pour que les clients puissent avoir accès au Web.

Partie 5 — Sécurité réseau et segmentation

Situation initiale

Toutes les machines se trouvent dans le même réseau.

5.1 Analyse des risques

Identifiez :

- les menaces,
- les vulnérabilités,
- les impacts métiers.

5.2 Segmentation réseau

À partir du réseau :

192.168.50.0/24

proposez :

- un sous-réseau Serveurs,
- un sous-réseau Clients,
- un sous-réseau Administration,
- un sous-réseau isolé pour Parrot.

Pour chaque sous-réseau, donnez :

- adresse réseau,
- masque,
- plage d'adresses utilisables,
- broadcast.

Partie 6 — GPO et sécurité Active Directory

Contexte

L'entreprise souhaite renforcer la sécurité des postes utilisateurs.

Travail demandé

Proposez des GPO permettant :

- des mots de passe complexes,
- le verrouillage automatique de session,
- l'interdiction du panneau de configuration,
- le blocage des périphériques USB,
- la limitation des droits utilisateurs,
- l'interdiction d'installation de logiciels.

Questions

1. Pourquoi les GPO sont-elles importantes ?
2. Quels risques existent sans stratégie de groupe ?
3. Pourquoi faut-il limiter les droits des utilisateurs ?
4. Pourquoi la séparation des rôles administratifs est-elle importante ?

Partie 7 — Analyse finale

Expliquez :

1. Pourquoi la méthode MoSCoW aide à prioriser les besoins de sécurité.
2. Pourquoi AD DS est central dans une infrastructure Windows.
3. Pourquoi DNS est indispensable au fonctionnement du domaine.
4. Pourquoi DHCP simplifie l'administration réseau.
5. Pourquoi IIS représente une cible sensible.
6. Comment la segmentation réduit les risques de compromission.
7. Pourquoi les GPO renforcent la sécurité globale du système.